Audit de sécurité — Nhill 0.1.0 → 2.0.0

> **Date :** 26 octobre 2026 · **Nature :** revue de code et de configuration (« boîte blanche »), vérification des dépendances contre les bases de vulnérabilités publiques. **Ce n'est pas un test d'intrusion** : aucun serveur Nhill n'a pu être exécuté dans l'environnement d'audit (dépendances non installables). Aucune affirmation d'absence de vulnérabilité n'est faite. Les points marqués « vérifié » l'ont été par lecture du code source et, quand c'est indiqué, par exécution de tests.

1. Synthèse

Le modèle de sécurité de Nhill est **sérieux** : le serveur décide de tout (rôles, plafonds, abonnement), les établissements sont isolés par *row-level security* PostgreSQL forcée, les mots de passe sont hachés avec Argon2id, les jetons sont opaques, courts et tournants, les secrets de prestataires sont chiffrés, aucun secret n'est présent dans le dépôt, les sauvegardes sont chiffrées avec `age`.

Les risques principaux identifiés sont :

#	Risque	Gravité	Statut
S1	**cpp-httplib 0.14** : CVE-2025-46728 et CVE-2025-53629 (épuisement mémoire par requêtes « chunked », CVSS 7,5)	**Haute**	Atténué par Caddy (`request_body max_size 6MB`) ; **mise à niveau ≥ 0.23.0 à faire**
S2	**Runtime Qt 6.4.2 embarqué et figé** dans les paquets Debian 13 0.1.0 (ex. CVE-2024-39936, HTTP/2, corrigée dans Qt 6.5.7 / 6.7.3 et dans le qt6-base de Debian 13)	**Haute**	2.0.0 : paquets Debian 13 **natifs** (Qt du système, mis à jour par Debian) via la CI ; variante embarquée déconseillée
S3	**Aucune récupération de compte** : un propriétaire qui oublie son mot de passe perd l'accès ; risque de contournements dangereux (comptes partagés)	Haute (exploitation)	Ouvert — exige l'envoi d'e-mails
S4	**Longueur minimale réduite à 8 caractères** (exigence) alors que NIST SP 800-63B-4 recommande 15 caractères pour un mot de passe utilisé seul	Moyenne (risque accepté)	Compensations : liste de mots de passe interdits élargie, limitation des tentatives, Argon2id, fermeture des autres sessions au changement ; **décision à consigner par le propriétaire**
S5	`X-Forwarded-For` lu à gauche : falsifiable derrière un proxy qui *ajoute* l'en-tête (contournement des limites par IP)	Faible (le Caddyfile fourni remplace l'en-tête)	**Corrigé 2.0.0** (entrée de droite)
S6	Conformité « données personnelles » RDC non établie (déclaration à l'autorité, transfert hors RDC si hébergement Supabase à l'étranger, délégué à la protection des données)	Haute (juridique)	Voir dossier juridique ; actions à mener par l'exploitant
S7	Pas d'archivage continu des WAL : perte de données possible jusqu'à 24 h	Moyenne	Ouvert — recommandation
S8	Pas de supervision ni d'alerte (sauvegarde échouée, certificat, disque)	Moyenne	Ouvert — recommandation
S9	Recherche `ILIKE` avec caractères `%` et `_` non échappés (motifs fournis par l'utilisateur)	Faible	Ouvert — pas d'injection (paramètres liés), seulement des motifs plus larges

2. Périmètre et modèle de menace

- **Actifs :** données commerciales des établissements (clients, factures, stock, paiements), comptes et sessions, secrets de la plate-forme (`NH_SECRET_KEY`, secrets de webhooks, identifiants de base), sauvegardes, journal d'audit.
- **Acteurs malveillants considérés :** internaute anonyme ; utilisateur authentifié d'un autre établissement ; employé aux droits limités (caissier) ; ancien employé ; personne ayant obtenu un code d'établissement ; administrateur de la console aux droits limités ; attaquant réseau sur un Wi-Fi public.
- **Hors périmètre :** compromission du poste de l'utilisateur ou de l'hébergeur, attaques physiques, déni de service volumétrique.

3. Contrôles vérifiés

Domaine	Contrôle	Preuve
Authentification	Argon2id (libsodium), paramètres configurables (`NH_ARGON2_OPS=3`, `NH_ARGON2_MEM_KIB=65536`), rehachage à la connexion si les paramètres augmentent	`server/src/util/crypto.cpp`, `services/auth.cpp` l. 90-106
	Comparaison en temps constant ; hachage factice pour un e-mail inconnu (pas d'énumération par le temps)	`auth.cpp` l. 20, 95-101
	Règle de mot de passe partagée client/serveur : **≥ 8 caractères** (points de code Unicode), ≤ 128 octets, refus des mots de passe courants (40 entrées), répétitifs ou égaux à l'e-mail ; aucune règle de composition, aucune expiration périodique	`common/src/validation.cpp` ; tests `Validation.*` **exécutés : 20/20**
	Changement de mot de passe : vérifie l'ancien, ferme les autres sessions, audit	`auth.cpp` l. 268-287 ; test `Auth.LogoutAndPasswordChangeRevokeSessions`
	Limitation des tentatives en base (8/15 min par e-mail, 40 par IP, etc.)	`services/common.cpp` (`throttle`) ; test `Auth.BruteForceIsThrottled`
Sessions	Jetons opaques 32 octets, seul le SHA-256 est stocké ; accès 15 min ; rafraîchissement 30 jours, rotation, réutilisation → révocation de la famille	`auth.cpp`, test `Auth.LoginRefreshRotationAndReuseDetection`
	Client : jeton de rafraîchissement dans le trousseau (QtKeychain), jamais en clair ; console : jeton en mémoire	`client/src/core/session.cpp`
A2F	**Non imposée** aux utilisateurs des établissements (exigence) ; **obligatoire (TOTP RFC 6238, code non rejouable) pour la console** de la plate-forme	`services/admin.cpp` l. 49-130
Autorisations	Rôles × permissions vérifiés côté serveur sur chaque route ; abonnement suspendu → lecture seule ; établissement suspendu/fermé	`http/app.cpp` (`roleHas`, `wrap`)

Domaine	Contrôle	Preuve
Isolation	RLS **forcée** sur 30 tables métier, contexte d'établissement par transaction, rôle applicatif `NOBYPASSRLS` sans propriété d'objet ; violation RLS → 404 sans détail ; tests d'isolation inter-établissements	`db/migrations/0003_security.sql`, `app.cpp` (`42501` → 404), tests `Isolation.*`
Injection SQL	Toutes les valeurs passent en paramètres liés (`$1…`) ; les fragments dynamiques sont des constantes du code ; noms d'objets via `quote_name`	revue de `services/*.cpp`, `setup.cpp`
Validation des entrées	JSON objet obligatoire, longueurs, e-mails, téléphones, UUID, dates, montants à précision fixe, énumérations	`services/common.*`, `common/validation`
Transport	Client : HTTPS obligatoire sauf adresse locale (`insecure_url`) ; serveur derrière Caddy (TLS automatique, HSTS, `nosniff`, `DENY`, `no-referrer`) ; serveur à l'écoute sur 127.0.0.1	`client/src/core/apiclient.cpp` l. 50-92, `deploy/caddy/Caddyfile`
En-têtes API	`X-Content-Type-Options`, `X-Frame-Options`, `Referrer-Policy`, `Cache-Control: no-store` ; corps ≤ 8 Mio, délais de lecture/écriture	`app.cpp` (constructeur)
Secrets	Aucun secret dans le dépôt (recherche de motifs : clés Stripe, AWS, JWT, clés privées, mots de passe littéraux — 0 résultat hors exemples) ; `server.env` refusé s'il est lisible par d'autres ; secrets de prestataires en écriture seule et chiffrés (secretbox)	recherche automatisée ; `config.cpp`
Journaux	Pas de mot de passe ni de jeton dans les journaux ; e-mails masqués ; rapports d'erreur des applications filtrés (chaîne « password » rejetée, données personnelles masquées)	`jobs.cpp` l. 163, `appcontext.cpp` l. 257, test `Support.*`
Webhooks	Signature HMAC/prestataire, horodatage, montant vérifiés ; traitement idempotent	`subscriptions.cpp` l. 601-630, tests `Webhook.*`
Sauvegardes	`pg_dump`	age (`le vidage en clair ne touche jamais le disque`), rôle `nhill_backup` dédié, rotation
Installation	Jeton d'installation à usage unique (60 min) affiché dans le journal local ; mots de passe des rôles générés (192 bits) ; fichier de configuration écrit atomiquement en 0600	`setup.cpp`, tests `Setup.*`

4. Vulnérabilités des dépendances

Dépendance (version livrée)	Vulnérabilité	Effet	Correction	Situation Nhill
cpp-httplib 0.14	**CVE-2025-46728** (NVD, CVSS 3.1 : 7,5) — limites de taille non appliquées aux corps « chunked » ou sans `Content-Length`	Épuisement mémoire, arrêt du serveur	0.20.1	Paquet Ubuntu 24.04 / copie embarquée Debian 13 en 0.14
cpp-httplib 0.14	**CVE-2025-53629** (NVD, CVSS 7,5) — allocation mémoire sans limite avec `Transfer-Encoding: chunked`	Idem	0.23.0	Idem. **Atténuation en place** : Caddy rejette les corps > 6 Mo avant le serveur (contournement recommandé par l'avis). **Action** : vendre cpp-httplib ≥ 0.23 (en-tête unique)
Qt 6.4.2 (runtime embarqué des paquets Debian 13 0.1.0)	**CVE-2024-39936** (HTTP/2 : décisions de sécurité avant `encrypted()`), et autres avis Qt postérieurs	Selon l'avis	Qt 6.5.7 / 6.7.3 ; Debian 13 `qt6-base` `6.8.2+dfsg-9+deb13u2` corrigé	2.0.0 : construire les paquets Debian 13 contre le Qt du système
libharu 2.3.0, libsodium 1.0.18, libpqxx 7.8	Aucun avis bloquant identifié pendant l'audit	—	—	Mises à jour par la distribution quand elles sont liées dynamiquement

5. Politique de mots de passe et d'A2F (décision 2.0.0)

Exigence du propriétaire : minimum 8 caractères, pas de changement périodique arbitraire, pas d'A2F systématique.

Mise en œuvre :

1. Minimum **8 caractères** (points de code, pas octets) à la création de compte (nouvel établissement), à l'adhésion par invitation, au changement de mot de passe et au premier accès à la console. Il n'existe pas de parcours de réinitialisation : la règle s'y appliquera dès sa création (même fonction partagée `checkPassword`).
2. Validation **côté interface** (instantanée, même code C++) **et côté serveur** (autoritaire).
3. Conservés : Argon2id, refus des mots de passe courants/répétitifs/égaux à l'e-mail, limitation des tentatives, révocation des sessions au changement.
4. **A2F :** non imposée aux utilisateurs des établissements ; **maintenue obligatoire pour la console de la plate-forme**, dont les comptes peuvent suspendre des établissements, gérer les abonnements et les prestataires de paiement : la retirer supprimerait une protection indispensable. Avec l'A2F, 8 caractères respectent le minimum de NIST SP 800-63B-4 § 3.1.1.2 pour un mot de passe utilisé dans une authentification multifacteur.
5. **Risque résiduel (S4) :** pour un mot de passe utilisé seul, NIST SP 800-63B-4 demande au moins 15 caractères. Recommandations : proposer l'A2F en option aux propriétaires (évolution), vérifier les mots de passe contre une liste de mots de passe compromis (k-anonymat), et conserver la limitation des tentatives.

6. Données personnelles et multi-établissements

- **Séparation des données clients :** assurée par RLS forcée + requêtes serveur ; testée.

- **Statistiques de la plate-forme :** agrégats sans données nominatives, consultation visible par l'établissement (à mentionner dans la politique de confidentialité).
- **Journal d'activité des employés :** traitement de données personnelles de salariés — information du personnel requise.
- **Cadre RDC :** Ordonnance-loi n° 23/010 du 13 mars 2023 portant Code du numérique (Livre III, données personnelles) ; autorité de protection des données exercée à titre provisoire par l'ARPTC ; décision n° 039/ARPTC/CLG/2025 du 11 septembre 2025 (déclaration, autorisation, transferts, frais). Si la base est hébergée hors de RDC (ex. Supabase), le **transfert** relève d'une autorisation préalable (art. 187 et 201-202 selon les commentaires disponibles). Détails, sources et réserves : `legal/fr/00-recherche-juridique.md`.

7. Risques résiduels et actions

Priorité	Action	Responsable
1	Vendre cpp-httplib ≥ 0.23.0 et relancer les tests serveur ; garder la limite de corps de Caddy	Développement
2	Paquets Debian 13 natifs (CI `linux-packages.yml`) ; retirer la variante à runtime embarqué	Développement
3	Transport e-mail (SMTP avec TLS) puis réinitialisation de mot de passe par lien à usage unique (15 min, haché en base), A2F optionnelle pour les propriétaires	Développement
4	Déclarations « données personnelles » et, si hébergement hors RDC, autorisation de transfert ; désignation d'un délégué à la protection des données ; registre des traitements	Exploitant + juriste
5	Archivage continu des WAL ou offre Supabase avec PITR ; test de restauration trimestriel	Exploitation
6	Supervision : `/health`, échecs de sauvegarde, expiration TLS, espace disque, erreurs 5xx	Exploitation
7	Test d'intrusion externe avant l'ouverture commerciale large	Exploitant
8	Échapper `%` / `_` dans les recherches `ILIKE`	Développement

8. Sources

- NVD — CVE-2025-46728 : https://nvd.nist.gov/vuln/detail/CVE-2025-46728 (résumé Tenable : https://www.tenable.com/cve/CVE-2025-46728)
- NVD — CVE-2025-53629 : https://nvd.nist.gov/vuln/detail/CVE-2025-53629
- Debian Security Tracker — CVE-2024-39936 : https://security-tracker.debian.org/tracker/CVE-2024-39936
- NIST SP 800-63B-4, § 3.1.1.2 (mots de passe) : https://pages.nist.gov/800-63-4/sp800-63b.html
- Code du numérique (RDC), texte publié par Droit-Numérique.cd : https://droitnumerique.cd/code-du-numerique-congolais-rdc-pdf/
- Avocats.cd — conformité des entreprises (décision ARPTC 039/2025) : https://avocats.cd/blog/donnees-personnelles-en-rdc-comment-les-entreprises-doivent-se-conformer
- Droit-Numérique.cd — transferts hors RDC : https://droitnumerique.cd/le-transfert-des-donnees-personnelles-hors-de-la-rd-congo/